TECHNICAL COMPLIANCE READINESS REPORT

becode-2026

NIS2 | DORA | CRA | ISO/IEC 27001:2022 | ISO/IEC 27005:2022 | AI Act | GDPR

Generated 2026-10-30 23:17 UTC | commit 5bbf997 on add-compliance-check

compliance-check 1.0.0 | 38 automated checks | 94 files scanned

Summary

15 controls in place

10 partly in place

11 missing

1 need a manual check

1 not applicable

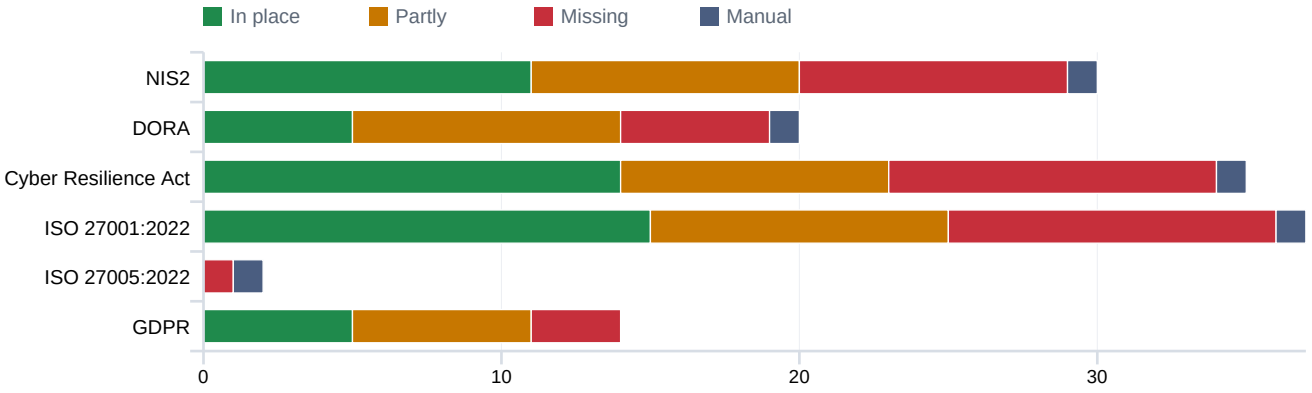
This report scans the **becode-2026** repository (3 Python projects, 94 files) against technical requirements derived from seven frameworks. **15** of 37 applicable controls are fully in place, **10** partly, and **11** are missing. The risk register lists **21** risks, 5 of them rated high.

Framework	Relation to this project	Readiness	Pass	Warn	Fail
NIS2	**Indirect**	**53%**	11	9	9
DORA	**Indirect**	**50%**	5	9	5
Cyber Resilience Act	**Likely out of scope**	**54%**	14	9	11
ISO/IEC 27001:2022	**Voluntary**	**56%**	15	10	11
ISO/IEC 27005:2022	**Voluntary**	**0%**	0	0	1
AI Act	**Not applicable**	-	0	0	0
GDPR	**Applies**	**57%**	5	6	3

What this report is, and isn't. A script can verify technical controls in code, configuration and documentation. It cannot verify governance, contracts, training, or legal applicability, which decide compliance. Readiness percentages show how many *automatically verifiable* controls are in place (partial counts half); they are not a compliance score. Section 6 lists the organisational requirements to check by hand. Facts about the laws were verified on 31 October 2026.

1. Executive summary

Number of automated checks per framework and their result. One check can provide evidence for several frameworks (for example, missing dependency updates affect NIS2, DORA, the CRA and ISO 27001).



Top priorities

The highest-rated risks from the register (section 5), with what to do about each.

Risk	Level	What to do
R-01 Dependency updates are automated	High	Add .github/dependabot.yml (ecosystems: pip for each project folder, and github-actions) so vulnerable dependencies get update pull requests automatically.
R-02 Personal data processing is documented	High	Add a 'Privacy & personal data' section to each such README: which personal data the tool processes (usernames, email addresses, IPs, hostnames), why, where it is stored, for how long, and which third parties receive any of it. A SOC using it typically relies on legitimate interest (GDPR Art. 6(1)(f), Recital 49: network and information security).
R-03 Stored personal data has a retention limit	High	Add a retention setting and a purge command (e.g. `mini-siem purge --older-than 90d`) that deletes old events, alerts and IOC results, and document the default retention period.
R-04 A vulnerability disclosure policy exists	High	Add a SECURITY.md: how to report a vulnerability privately (email or GitHub private vulnerability reporting), what reporters can expect and when, and which versions get fixes.
R-05 A documented risk assessment or threat model exists	High	Write a THREAT_MODEL.md per project: assets, threats (e.g. STRIDE), likelihood and impact, chosen treatment, and the risk owner. The risk register in this report is a starting point.
R-06 Security-focused code scanning is enabled	Medium	Enable ruff's security rules (add "S" to `select` in each pyproject.toml), or run bandit or GitHub CodeQL in CI.
R-07 Forms are protected against cross-site request forgery	Medium	Add CSRF tokens to every POST form (e.g. Flask-WTF's CSRFProtect). Without them, any website the analyst visits can send a hidden request to the dashboard on 127.0.0.1 and close alerts.

What is already in place

SEC-01 No secrets hard-coded in the repository; **SEC-02** Local secrets files are excluded from git; **SEC-03** Encrypted connections are never downgraded; **SEC-04** Outbound network calls have timeouts; **DEV-01** Automated tests run in CI; **DEV-02** Static analysis (linting) runs in CI; **DEV-04** No dangerous code patterns; **DEV-06** Errors are not silently swallowed; **DEV-07** Changes are reviewed through pull requests; **WEB-01** Web pages escape untrusted data; **WEB-05** Debug mode is off; **PRIV-02** Internal data is filtered before third-party lookups; **PRIV-04** Test and demo data contain no real personal data; **DOC-01** Each project has user documentation; **DOC-05** Licensing is clear.

2. Scope and applicability

Whether each framework applies depends on *who* uses the software and *how*. This section states how each one relates to the scanned project, based on what the scan found.

NIS2 EU directive (national law: Belgian NIS2 Act of 26 April 2024)

Indirect

Instrument	Directive (EU) 2022/2555 on a high common level of cybersecurity across the Union
Applies to	Essential and important entities in the sectors of Annexes I and II (energy, transport, banking, health, digital infrastructure, ICT service management, ...), usually medium and large organisations.
This project	**Indirect.** The project is not an entity, so NIS2 doesn't apply to it directly. It applies to an organisation in scope that uses these tools: their security then supports that organisation's Art. 21 measures (supply chain, secure development, incident handling).
Key dates	17 Oct 2024: transposition deadline; Belgian law in force since 18 Oct 2024 18 Apr 2026: Belgian essential entities had to show CyberFundamentals or ISO 27001 progress (CCB) Incident reporting: 24 h early warning, 72 h notification, final report within 1 month (Art. 23)

DORA EU regulation

Indirect

Instrument	Regulation (EU) 2022/2554 on digital operational resilience for the financial sector
Applies to	Financial entities (banks, insurers, investment firms, payment institutions, crypto-asset providers, ...) and critical ICT third-party service providers.
This project	**Indirect.** Only financial entities and their ICT providers are in scope. If a bank's SOC used these tools, they would fall under its ICT risk management (Art. 6-16) and third-party risk (Art. 28-30).
Key dates	17 Jan 2025: applies in full Major ICT incidents: initial notification within 4 h of classification (max 24 h from detection), intermediate report within 72 h, final report within 1 month

Cyber Resilience Act EU regulation

Likely out of scope

Instrument	Regulation (EU) 2024/2847 on horizontal cybersecurity requirements for products with digital elements
Applies to	Manufacturers, importers and distributors of products with digital elements (hardware and software) made available on the EU market in the course of a commercial activity.
This project	**Likely out of scope.** Free and open-source software developed or supplied outside a commercial activity is excluded (Recitals 18-19). This portfolio project isn't sold or monetised, so the CRA most likely doesn't apply. It becomes mandatory if the tools are ever sold or offered as part of a paid service, so its essential requirements are used here as a best-practice baseline.
Key dates	10 Dec 2024: entered into force 11 Sep 2026: reporting obligations apply (Art. 14): actively exploited vulnerabilities and severe incidents, 24 h early warning, 72 h notification, final report 11 Dec 2027: all obligations apply (essential requirements, conformity assessment, CE marking)

ISO/IEC 27001:2022 International standard (voluntary, certifiable)

Voluntary

Instrument	Information security management systems: requirements
Applies to	Any organisation that wants a certified information security management system (ISMS). Annex A lists 93 controls in 4 themes.
This project	**Voluntary.** A certification standard for an organisation's ISMS, not for a code repository. The Annex A technical controls the code can show (secure development, cryptography, logging, vulnerability management) are assessed; the management clauses 4-10 are listed as manual checks.
Key dates	31 Oct 2025: end of the transition period from the 2013 edition Recognised path for Belgian NIS2 compliance (CCB)

ISO/IEC 27005:2022 International standard (guidance, not certifiable)

Voluntary

Instrument	Guidance on managing information security risks
Applies to	Any organisation running information security risk management, typically to support ISO 27001 clauses 6.1 and 8.
This project	**Voluntary.** Guidance for the risk management process. The report derives a starting risk register from the findings (clauses 7.2-7.4) and checks whether a risk assessment is documented.
Key dates	Fourth edition, October 2022, aligned with ISO 27001:2022

AI Act EU regulation

Not applicable

Instrument	Regulation (EU) 2024/1689 laying down harmonised rules on artificial intelligence, as amended by the Digital Omnibus on AI, Regulation (EU) 2026/1744
Applies to	Providers and deployers of AI systems placed on the market or used in the EU.
This project	**Not applicable.** No AI system was found: no machine-learning or LLM library is imported or declared, and there are no model files. The scoring is rule-based, with thresholds written by a person, which the AI system definition (Art. 3(1)) excludes.
Key dates	2 Feb 2025: prohibited practices (Art. 5) and AI literacy (Art. 4) apply 2 Aug 2025: general-purpose AI model obligations apply 2 Aug 2026: transparency obligations (Art. 50) apply 2 Dec 2027: high-risk systems of Annex III (postponed from Aug 2026 by Regulation (EU) 2026/1744) 2 Aug 2028: high-risk AI in products covered by Annex I

GDPR EU regulation

Applies

Instrument	Regulation (EU) 2016/679 on the protection of personal data
Applies to	Anyone processing personal data of people in the EU. IP addresses, usernames, email addresses and hostnames linked to a person are personal data.
This project	**Applies.** Personal data is processed by: mini-siem. The tools handle usernames, email addresses, IP addresses and hostnames from logs. The test data is fictional, but GDPR applies in full as soon as real logs are ingested. A SOC normally relies on legitimate interest for network security (Art. 6(1)(f), Recital 49).
Key dates	25 May 2018: applies Data breaches: notify the authority within 72 h (Art. 33)

3. Results by framework

Each referenced article, annex point or control, with the checks that provide evidence for it. Details for every check are in section 4.

NIS2 - readiness 53%

Indirect: The project is not an entity, so NIS2 doesn't apply to it directly.

Reference	Requirement	Check	Result
Art. 12	Coordinated vulnerability disclosure	DOC-02 A vulnerability disclosure policy exists	FAIL
Art. 21(1)	Appropriate and proportionate risk-management measures	RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 21(2)(a)	Policies on risk analysis and information system security	PRIV-01 Personal data processing is documented	FAIL
		PRIV-03 Stored personal data has a retention limit	FAIL
		RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 21(2)(b)	Incident handling	LOG-01 Security-relevant actions are logged	WARN
		INC-01 An incident and vulnerability response procedure is documented	FAIL
Art. 21(2)(c)	Business continuity, backup management and disaster recovery	RES-01 Stored data can be backed up and restored	WARN
Art. 21(2)(d)	Supply chain security	SC-01 Third-party dependencies are declared with versions	WARN
		SC-02 A software bill of materials (SBOM) is available	WARN
		SC-05 CI uses third-party actions pinned to a commit	WARN
		PRIV-02 Internal data is filtered before third-party lookups	PASS
		PRIV-06 Third-party data recipients are disclosed	WARN
Art. 21(2)(e)	Security in acquisition, development and maintenance, incl. vulnerability handling and disclosure	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-04 Outbound network calls have timeouts	PASS
		SC-03 Dependencies have no known vulnerabilities	MANUAL
		SC-04 Dependency updates are automated	FAIL
		DEV-01 Automated tests run in CI	PASS
		DEV-02 Static analysis (linting) runs in CI	PASS
		DEV-03 Security-focused code scanning is enabled	FAIL
		DEV-04 No dangerous code patterns	PASS
		DEV-05 Database queries are parameterised	WARN
		DEV-07 Changes are reviewed through pull requests	PASS

Reference	Requirement	Check	Result
		WEB-01 Web pages escape untrusted data	PASS
		WEB-02 Forms are protected against cross-site request forgery	FAIL
		DOC-02 A vulnerability disclosure policy exists	FAIL
Art. 21(2)(f)	Assessing the effectiveness of cybersecurity measures	DEV-01 Automated tests run in CI	PASS
Art. 21(2)(g)	Basic cyber hygiene practices and cybersecurity training	DOC-01 Each project has user documentation	PASS
Art. 21(2)(h)	Cryptography and, where appropriate, encryption	SEC-03 Encrypted connections are never downgraded	PASS
		PRIV-05 Stored personal data is encrypted at rest	WARN
Art. 21(2)(i)	Human resources security, access control and asset management	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-02 Local secrets files are excluded from git	PASS
		SC-06 CI jobs run with least-privilege tokens	FAIL
		WEB-02 Forms are protected against cross-site request forgery	FAIL
		WEB-03 The web interface requires authentication	WARN
Art. 21(2)(j)	Multi-factor authentication and secured communications	SEC-03 Encrypted connections are never downgraded	PASS
		WEB-03 The web interface requires authentication	WARN
Art. 23	Reporting obligations for significant incidents	INC-01 An incident and vulnerability response procedure is documented	FAIL

DORA - readiness 50%

Indirect: Only financial entities and their ICT providers are in scope.

Reference	Requirement	Check	Result
Art. 6	ICT risk management framework	RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 8	Identification of ICT assets, dependencies and risks	SC-01 Third-party dependencies are declared with versions	WARN
		SC-02 A software bill of materials (SBOM) is available	WARN
		RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 9	Protection and prevention	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-03 Encrypted connections are never downgraded	PASS
		SEC-04 Outbound network calls have timeouts	PASS
		SC-03 Dependencies have no known vulnerabilities	MANUAL
		SC-04 Dependency updates are automated	FAIL
		SC-06 CI jobs run with least-privilege tokens	FAIL

Reference	Requirement	Check	Result
		DEV-07 Changes are reviewed through pull requests	PASS
		WEB-03 The web interface requires authentication	WARN
		PRIV-05 Stored personal data is encrypted at rest	WARN
		DOC-04 Releases are versioned with a change log	WARN
Art. 10	Detection of anomalous activities	SC-03 Dependencies have no known vulnerabilities	MANUAL
		LOG-01 Security-relevant actions are logged	WARN
		DOC-02 A vulnerability disclosure policy exists	FAIL
Art. 11	Response and recovery	RES-01 Stored data can be backed up and restored	WARN
Art. 12	Backup policies, restoration and recovery	LOG-01 Security-relevant actions are logged	WARN
		RES-01 Stored data can be backed up and restored	WARN
Art. 17	ICT-related incident management process	INC-01 An incident and vulnerability response procedure is documented	FAIL
Art. 19	Reporting of major ICT-related incidents	INC-01 An incident and vulnerability response procedure is documented	FAIL
Art. 25	Testing of ICT tools and systems	DEV-01 Automated tests run in CI	PASS
Art. 28	Managing ICT third-party risk	SC-01 Third-party dependencies are declared with versions	WARN
		SC-05 CI uses third-party actions pinned to a commit	WARN
		PRIV-06 Third-party data recipients are disclosed	WARN

Cyber Resilience Act - readiness 54%

Likely out of scope: Free and open-source software developed or supplied outside a commercial activity is excluded (Recitals 18-19).

Reference	Requirement	Check	Result
Annex I, Part I(2)(a)	Made available without known exploitable vulnerabilities	SC-03 Dependencies have no known vulnerabilities	MANUAL
		DEV-03 Security-focused code scanning is enabled	FAIL
Annex I, Part I(2)(b)	Secure-by-default configuration	WEB-04 HTTP security headers are set	FAIL
		WEB-05 Debug mode is off	PASS
Annex I, Part I(2)(c)	Vulnerabilities can be addressed through security updates	SC-04 Dependency updates are automated	FAIL
Annex I, Part I(2)(d)	Protection from unauthorised access (authentication, access management)	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-02 Local secrets files are excluded from git	PASS
		WEB-02 Forms are protected against cross-site request forgery	FAIL
		WEB-03 The web interface requires authentication	WARN

Reference	Requirement	Check	Result
Annex I, Part I(2)(e)	Confidentiality of stored and transmitted data (e.g. encryption)	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-03 Encrypted connections are never downgraded	PASS
		PRIV-05 Stored personal data is encrypted at rest	WARN
Annex I, Part I(2)(f)	Integrity of data, commands and programs	SEC-03 Encrypted connections are never downgraded	PASS
		SC-05 CI uses third-party actions pinned to a commit	WARN
		DEV-05 Database queries are parameterised	WARN
		WEB-01 Web pages escape untrusted data	PASS
		WEB-02 Forms are protected against cross-site request forgery	FAIL
Annex I, Part I(2)(g)	Data minimisation	PRIV-02 Internal data is filtered before third-party lookups	PASS
Annex I, Part I(2)(h)	Availability of essential functions	SEC-04 Outbound network calls have timeouts	PASS
		RES-01 Stored data can be backed up and restored	WARN
Annex I, Part I(2)(j)	Limiting attack surfaces	SC-06 CI jobs run with least-privilege tokens	FAIL
		DEV-04 No dangerous code patterns	PASS
		DEV-05 Database queries are parameterised	WARN
		WEB-01 Web pages escape untrusted data	PASS
		WEB-04 HTTP security headers are set	FAIL
Annex I, Part I(2)(k)	Reducing the impact of an incident (exploitation mitigation)	DEV-04 No dangerous code patterns	PASS
Annex I, Part I(2)(l)	Recording and monitoring of security-relevant internal activity	DEV-06 Errors are not silently swallowed	PASS
		LOG-01 Security-relevant actions are logged	WARN
Annex I, Part I(2)(m)	Secure and easy removal of data and settings	PRIV-03 Stored personal data has a retention limit	FAIL
Annex I, Part II(1)	Identify and document vulnerabilities and components, incl. an SBOM	SC-01 Third-party dependencies are declared with versions	WARN
		SC-02 A software bill of materials (SBOM) is available	WARN
		DOC-05 Licensing is clear	PASS
Annex I, Part II(2)	Address and remediate vulnerabilities without delay	SC-03 Dependencies have no known vulnerabilities	MANUAL
		SC-04 Dependency updates are automated	FAIL
Annex I, Part II(3)	Regular tests and reviews of security	DEV-01 Automated tests run in CI	PASS
		DEV-02 Static analysis (linting) runs in CI	PASS
		DEV-03 Security-focused code scanning is enabled	FAIL

Reference	Requirement	Check	Result
		DEV-07 Changes are reviewed through pull requests	PASS
Annex I, Part II(4)	Publicly disclose fixed vulnerabilities	DOC-04 Releases are versioned with a change log	WARN
Annex I, Part II(5)	Coordinated vulnerability disclosure policy	DOC-02 A vulnerability disclosure policy exists	FAIL
Annex I, Part II(6)	Contact address for reporting vulnerabilities	DOC-02 A vulnerability disclosure policy exists	FAIL
Annex II	Information and instructions for the user	PRIV-01 Personal data processing is documented	FAIL
		DOC-01 Each project has user documentation	PASS
		DOC-03 The security support period is stated	FAIL
		DOC-04 Releases are versioned with a change log	WARN
Annex VII	Technical documentation	SC-02 A software bill of materials (SBOM) is available	WARN
		RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 13(2)	Cybersecurity risk assessment of the product	RISK-01 A documented risk assessment or threat model exists	FAIL
Art. 13(8)	Support period (at least 5 years unless the product is expected to be used for less)	DOC-03 The security support period is stated	FAIL
Art. 13(17)	Single point of contact for vulnerability reports	DOC-02 A vulnerability disclosure policy exists	FAIL
Art. 14	Reporting of actively exploited vulnerabilities and severe incidents	INC-01 An incident and vulnerability response procedure is documented	FAIL

ISO/IEC 27001:2022 - readiness 56%

Voluntary: A certification standard for an organisation's ISMS, not for a code repository.

Reference	Requirement	Check	Result
6.1.2	Information security risk assessment	RISK-01 A documented risk assessment or threat model exists	FAIL
6.1.3	Information security risk treatment	RISK-01 A documented risk assessment or threat model exists	FAIL
8.2	Performing risk assessments	RISK-01 A documented risk assessment or threat model exists	FAIL
A.5.9	Inventory of information and other associated assets	SC-02 A software bill of materials (SBOM) is available	WARN
A.5.14	Information transfer	SEC-03 Encrypted connections are never downgraded	PASS
		PRIV-02 Internal data is filtered before third-party lookups	PASS
		PRIV-06 Third-party data recipients are disclosed	WARN
A.5.15	Access control	SC-06 CI jobs run with least-privilege tokens	FAIL
		WEB-03 The web interface requires authentication	WARN
A.5.17	Authentication information	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-02 Local secrets files are excluded from git	PASS

Reference	Requirement	Check	Result
A.5.19	Information security in supplier relationships	PRIV-06 Third-party data recipients are disclosed	WARN
A.5.21	Managing security in the ICT supply chain	SC-01 Third-party dependencies are declared with versions	WARN
		SC-02 A software bill of materials (SBOM) is available	WARN
		SC-05 CI uses third-party actions pinned to a commit	WARN
A.5.24	Incident management planning and preparation	DOC-02 A vulnerability disclosure policy exists	FAIL
		INC-01 An incident and vulnerability response procedure is documented	FAIL
A.5.26	Response to information security incidents	INC-01 An incident and vulnerability response procedure is documented	FAIL
A.5.32	Intellectual property rights	DOC-05 Licensing is clear	PASS
A.5.33	Protection of records	PRIV-05 Stored personal data is encrypted at rest	WARN
A.5.34	Privacy and protection of PII	PRIV-01 Personal data processing is documented	FAIL
A.5.37	Documented operating procedures	DOC-01 Each project has user documentation	PASS
A.8.2	Privileged access rights	SC-06 CI jobs run with least-privilege tokens	FAIL
A.8.3	Information access restriction	WEB-03 The web interface requires authentication	WARN
A.8.5	Secure authentication	WEB-03 The web interface requires authentication	WARN
A.8.8	Management of technical vulnerabilities	SC-03 Dependencies have no known vulnerabilities	MANUAL
		SC-04 Dependency updates are automated	FAIL
		DOC-02 A vulnerability disclosure policy exists	FAIL
		DOC-03 The security support period is stated	FAIL
A.8.9	Configuration management	SEC-02 Local secrets files are excluded from git	PASS
		SC-01 Third-party dependencies are declared with versions	WARN
		WEB-04 HTTP security headers are set	FAIL
		WEB-05 Debug mode is off	PASS
A.8.10	Information deletion	PRIV-03 Stored personal data has a retention limit	FAIL
A.8.11	Data masking	PRIV-04 Test and demo data contain no real personal data	PASS
A.8.12	Data leakage prevention	PRIV-02 Internal data is filtered before third-party lookups	PASS
A.8.13	Information backup	RES-01 Stored data can be backed up and restored	WARN
A.8.15	Logging	DEV-06 Errors are not silently swallowed	PASS
		LOG-01 Security-relevant actions are logged	WARN
A.8.16	Monitoring activities	LOG-01 Security-relevant actions are logged	WARN

Reference	Requirement	Check	Result
A.8.24	Use of cryptography	SEC-03 Encrypted connections are never downgraded	PASS
		PRIV-05 Stored personal data is encrypted at rest	WARN
A.8.25	Secure development life cycle	DEV-01 Automated tests run in CI	PASS
		DEV-07 Changes are reviewed through pull requests	PASS
A.8.26	Application security requirements	WEB-01 Web pages escape untrusted data	PASS
		WEB-02 Forms are protected against cross-site request forgery	FAIL
		WEB-04 HTTP security headers are set	FAIL
A.8.28	Secure coding	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-04 Outbound network calls have timeouts	PASS
		DEV-02 Static analysis (linting) runs in CI	PASS
		DEV-03 Security-focused code scanning is enabled	FAIL
		DEV-04 No dangerous code patterns	PASS
		DEV-05 Database queries are parameterised	WARN
		DEV-06 Errors are not silently swallowed	PASS
		WEB-01 Web pages escape untrusted data	PASS
		WEB-02 Forms are protected against cross-site request forgery	FAIL
A.8.29	Security testing in development and acceptance	DEV-01 Automated tests run in CI	PASS
		DEV-03 Security-focused code scanning is enabled	FAIL
A.8.31	Separation of development, test and production environments	WEB-05 Debug mode is off	PASS
A.8.32	Change management	SC-05 CI uses third-party actions pinned to a commit	WARN
		DEV-07 Changes are reviewed through pull requests	PASS
		DOC-04 Releases are versioned with a change log	WARN
A.8.33	Test information	PRIV-04 Test and demo data contain no real personal data	PASS

ISO/IEC 27005:2022 - readiness 0%

Voluntary: Guidance for the risk management process.

Reference	Requirement	Check	Result
6	Context establishment (risk criteria, acceptance criteria)	RISK-01 A documented risk assessment or threat model exists	FAIL
7.2	Identifying information security risks	SC-03 Dependencies have no known vulnerabilities	MANUAL

Reference	Requirement	Check	Result
		RISK-01 A documented risk assessment or threat model exists	FAIL
7.3	Analysing information security risks (likelihood and consequences)	RISK-01 A documented risk assessment or threat model exists	FAIL
7.4	Evaluating information security risks	RISK-01 A documented risk assessment or threat model exists	FAIL
8	Information security risk treatment	RISK-01 A documented risk assessment or threat model exists	FAIL

AI Act

Not applicable: No AI system was found: no machine-learning or LLM library is imported or declared, and there are no model files.

Reference	Requirement	Check	Result
Art. 3(1)	Definition of an AI system	AI-01 Use of AI systems (AI Act scope)	N/A
Art. 4	AI literacy	AI-01 Use of AI systems (AI Act scope)	N/A
Art. 5	Prohibited AI practices	AI-01 Use of AI systems (AI Act scope)	N/A
Art. 6	Classification rules for high-risk AI systems	AI-01 Use of AI systems (AI Act scope)	N/A
Art. 50	Transparency obligations	AI-01 Use of AI systems (AI Act scope)	N/A

GDPR - readiness 57%

Applies: Personal data is processed by: mini-siem.

Reference	Requirement	Check	Result
Art. 5(1)(a)	Lawfulness, fairness and transparency	PRIV-01 Personal data processing is documented	FAIL
Art. 5(1)(c)	Data minimisation	PRIV-02 Internal data is filtered before third-party lookups	PASS
		PRIV-04 Test and demo data contain no real personal data	PASS
Art. 5(1)(e)	Storage limitation	PRIV-03 Stored personal data has a retention limit	FAIL
Art. 13	Information to be provided to data subjects	PRIV-01 Personal data processing is documented	FAIL
Art. 13(1)(e)	Recipients of the personal data	PRIV-06 Third-party data recipients are disclosed	WARN
Art. 17	Right to erasure	PRIV-03 Stored personal data has a retention limit	FAIL
Art. 25	Data protection by design and by default	PRIV-02 Internal data is filtered before third-party lookups	PASS
		PRIV-04 Test and demo data contain no real personal data	PASS
Art. 28	Processors	PRIV-06 Third-party data recipients are disclosed	WARN
Art. 30	Records of processing activities	PRIV-01 Personal data processing is documented	FAIL
Art. 32	Security of processing	SEC-01 No secrets hard-coded in the repository	PASS
		SEC-02 Local secrets files are excluded from git	PASS
		SEC-03 Encrypted connections are never downgraded	PASS
		DEV-05 Database queries are parameterised	WARN

Reference	Requirement	Check	Result
		WEB-03 The web interface requires authentication	WARN
		LOG-01 Security-relevant actions are logged	WARN
		PRIV-05 Stored personal data is encrypted at rest	WARN
		RES-01 Stored data can be backed up and restored	WARN
Art. 33	Notification of a breach to the supervisory authority	INC-01 An incident and vulnerability response procedure is documented	FAIL
Art. 34	Communication of a breach to the data subject	INC-01 An incident and vulnerability response procedure is documented	FAIL
Art. 44	General principle for transfers outside the EU	PRIV-02 Internal data is filtered before third-party lookups	PASS
		PRIV-06 Third-party data recipients are disclosed	WARN

4. Detailed findings

Every automated check: what was found, the evidence (file and line), what to do, and the references it supports.

Secrets & cryptography

SEC-01 No secrets hard-coded in the repository — PASS

No API keys, tokens, passwords or private keys found in 90 scanned files.

NIS2 Art. 21(2)(i), Art. 21(2)(e) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(d), Annex I, Part I(2)(e) **ISO/IEC 27001:2022** A.5.17, A.8.28 **GDPR** Art. 32

SEC-02 Local secrets files are excluded from git — PASS

.env is in .gitignore, and 2 .env.example file(s) contain empty values only.

```
example: ioc-enricher/.env.example
example: mini-siem/.env.example
```

NIS2 Art. 21(2)(i) **Cyber Resilience Act** Annex I, Part I(2)(d) **ISO/IEC 27001:2022** A.5.17, A.8.9 **GDPR** Art. 32

SEC-03 Encrypted connections are never downgraded — PASS

Certificate verification is never disabled, and all service endpoints use HTTPS.

NIS2 Art. 21(2)(h), Art. 21(2)(j) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(e), Annex I, Part I(2)(f) **ISO/IEC 27001:2022** A.8.24, A.5.14 **GDPR** Art. 32

SEC-04 Outbound network calls have timeouts — PASS

All 2 outbound HTTP call site(s) set a timeout.

NIS2 Art. 21(2)(e) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(h) **ISO/IEC 27001:2022** A.8.28

Supply chain

SC-01 Third-party dependencies are declared with versions — WARN

3 project(s) declare all dependencies with minimum versions, but there is no lock file pinning exact versions.

```
compliance-check: 4 runtime dependencies (reportlab>=4.0, pyyaml>=6.0, requests>=2.31, tomli>=2.0; python_version < '3.11')
ioc-enricher: 2 runtime dependencies (requests>=2.31, python-dotenv>=1.0)
mini-siem: 3 runtime dependencies (flask>=3.0, pyyaml>=6.0, python-dotenv>=1.0)
```

Recommendation: Declare every dependency in pyproject.toml with a minimum version, and use a lock file (e.g. pip-tools or uv) for reproducible builds.

NIS2 Art. 21(2)(d) **DORA** Art. 8, Art. 28 **Cyber Resilience Act** Annex I, Part II(1) **ISO/IEC 27001:2022** A.5.21, A.8.9

SC-02 A software bill of materials (SBOM) is available — WARN

No SBOM is published. This report lists the 8 declared component(s) in the appendix, and `--sbom` writes a CycloneDX file.

Recommendation: Generate a CycloneDX or SPDX SBOM in CI for every release (this tool writes one with --sbom) and publish it with the release.

NIS2 Art. 21(2)(d) **DORA** Art. 8 **Cyber Resilience Act** Annex I, Part II(1), Annex VII **ISO/IEC 27001:2022** A.5.9, A.5.21

SC-03 Dependencies have no known vulnerabilities MANUAL

Not checked: the scan ran offline. Use --online to query the OSV.dev vulnerability database for every installed dependency version.

Recommendation: Run this check with --online (queries the OSV.dev database), or add pip-audit to CI, and upgrade any vulnerable dependency.

NIS2 Art. 21(2)(e) **DORA** Art. 9, Art. 10 **Cyber Resilience Act** Annex I, Part I(2)(a), Annex I, Part II(2) **ISO/IEC 27001:2022** A.8.8 **ISO/IEC 27005:2022** 7.2

SC-04 Dependency updates are automated FAIL

No Dependabot or Renovate configuration: outdated or vulnerable dependencies are only found if someone looks.

Recommendation: Add .github/dependabot.yml (ecosystems: pip for each project folder, and github-actions) so vulnerable dependencies get update pull requests automatically.

NIS2 Art. 21(2)(e) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part II(2), Annex I, Part I(2)(c) **ISO/IEC 27001:2022** A.8.8

SC-05 CI uses third-party actions pinned to a commit WARN

7 action reference(s) use a movable tag instead of a commit SHA.

```
.github/workflows/compliance-check-ci.yml: actions/checkout@v4
.github/workflows/compliance-check-ci.yml: actions/setup-python@v5
.github/workflows/compliance-check-ci.yml: actions/upload-artifact@v4
.github/workflows/ioc-enricher-ci.yml: actions/checkout@v4
.github/workflows/ioc-enricher-ci.yml: actions/setup-python@v5
.github/workflows/mini-siem-ci.yml: actions/checkout@v4
.github/workflows/mini-siem-ci.yml: actions/setup-python@v5
```

Recommendation: Pin each `uses:` to a full commit SHA (with the version in a comment), and let Dependabot update them. A moved tag would otherwise run new code in CI without review.

NIS2 Art. 21(2)(d) **DORA** Art. 28 **Cyber Resilience Act** Annex I, Part I(2)(f) **ISO/IEC 27001:2022** A.5.21, A.8.32

SC-06 CI jobs run with least-privilege tokens FAIL

2 of 3 workflow(s) don't restrict the CI token.

```
.github/workflows/ioc-enricher-ci.yml: no `permissions:` block (the token gets the repository default)
.github/workflows/mini-siem-ci.yml: no `permissions:` block (the token gets the repository default)
```

Recommendation: Add `permissions: contents: read` at the top of each workflow, and grant more only to the jobs that need it.

NIS2 Art. 21(2)(i) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(j) **ISO/IEC 27001:2022** A.8.2, A.5.15

Secure development

DEV-01 Automated tests run in CI PASS

140 test functions in 15 files, run by 3 CI step(s).

```
.github/workflows/compliance-check-ci.yml: pytest -v
.github/workflows/ioc-enricher-ci.yml: pytest -v
.github/workflows/mini-siem-ci.yml: pytest -v
```

NIS2 Art. 21(2)(e), Art. 21(2)(f) **DORA** Art. 25 **Cyber Resilience Act** Annex I, Part II(3) **ISO/IEC 27001:2022** A.8.25, A.8.29

DEV-02 Static analysis (linting) runs in CI PASS

3 CI step(s) run static analysis.

```
.github/workflows/compliance-check-ci.yml: ruff check .
.github/workflows/ioc-enricher-ci.yml: ruff check .
.github/workflows/mini-siem-ci.yml: ruff check .
```

NIS2 Art. 21(2)(e) **Cyber Resilience Act** Annex I, Part II(3) **ISO/IEC 27001:2022** A.8.28

DEV-03 Security-focused code scanning is enabled — FAIL

No security scanner (ruff S rules, bandit, semgrep, CodeQL) is configured.

Recommendation: Enable ruff's security rules (add "S" to `select` in each pyproject.toml), or run bandit or GitHub CodeQL in CI.

NIS2 Art. 21(2)(e) **Cyber Resilience Act** Annex I, Part I(2)(a), Annex I, Part II(3) **ISO/IEC 27001:2022** A.8.28, A.8.29

DEV-04 No dangerous code patterns — PASS

No eval/exec, pickle, unsafe YAML or shell injection patterns in 52 Python files. 1 call(s) use only constant arguments (no injection possible).

```
ioc-enricher/tests/show_scenario.py:68: os.system() with a constant argument
```

NIS2 Art. 21(2)(e) **Cyber Resilience Act** Annex I, Part I(2)(j), Annex I, Part I(2)(k) **ISO/IEC 27001:2022** A.8.28

DEV-05 Database queries are parameterised — WARN

No SQL injection found: 7 queries build their structure dynamically, but every value is passed as a parameter or checked against a fixed allow-list. A manual review of these lines is still advisable.

```
mini-siem/src/mini_siem/store.py:103: structure built dynamically, values passed as parameters
mini-siem/src/mini_siem/store.py:119: structure built dynamically, values passed as parameters
mini-siem/src/mini_siem/store.py:120: structure built dynamically, values passed as parameters
mini-siem/src/mini_siem/store.py:127: inserts column, checked against a fixed allow-list
mini-siem/src/mini_siem/store.py:159: structure built dynamically, values passed as parameters
mini-siem/src/mini_siem/store.py:172: structure built dynamically, values passed as parameters
mini-siem/src/mini_siem/store.py:216: structure built dynamically, values passed as parameters
```

Recommendation: Review each query built with an f-string: values must go through ? placeholders, and any interpolated column or clause must come from a fixed allow-list, never from user input.

NIS2 Art. 21(2)(e) **Cyber Resilience Act** Annex I, Part I(2)(f), Annex I, Part I(2)(j) **ISO/IEC 27001:2022** A.8.28 **GDPR** Art. 32

DEV-06 Errors are not silently swallowed — PASS

No bare `except:` or silently ignored broad exceptions in application code.

Cyber Resilience Act Annex I, Part I(2)(l) **ISO/IEC 27001:2022** A.8.28, A.8.15

DEV-07 Changes are reviewed through pull requests — PASS

5 change(s) merged through pull requests; 1 commit(s) pushed directly to the main line. Branch protection itself can only be checked on GitHub.

```
Merge pull request #5 from Hauptfam/add-mini-siem
Merge pull request #4 from Hauptfam/add-dataset-doc
Merge pull request #3 from Hauptfam/add-scenario-test
Merge pull request #2 from Hauptfam/add-scenario-test
Merge pull request #1 from Hauptfam/add-ioc-enricher
direct: a38dbd3 Update .gitignore
```

NIS2 Art. 21(2)(e) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part II(3) **ISO/IEC 27001:2022** A.8.32, A.8.25

Web application

WEB-01 Web pages escape untrusted data — PASS

6 templates rely on Jinja autoescaping; no `|safe`, Markup() or disabled autoescape.

NIS2 Art. 21(2)(e) **Cyber Resilience Act** Annex I, Part I(2)(f), Annex I, Part I(2)(j) **ISO/IEC 27001:2022** A.8.28, A.8.26

WEB-02 Forms are protected against cross-site request forgery — FAIL

1 POST form(s) without CSRF tokens.

`mini-siem/src/mini_siem/templates/alert.html:78`

Recommendation: Add CSRF tokens to every POST form (e.g. Flask-WTF's CSRFProtect). Without them, any website the analyst visits can send a hidden request to the dashboard on 127.0.0.1 and close alerts.

NIS2 Art. 21(2)(e), Art. 21(2)(i) **Cyber Resilience Act** Annex I, Part I(2)(d), Annex I, Part I(2)(f) **ISO/IEC 27001:2022** A.8.26, A.8.28

WEB-03 The web interface requires authentication — WARN

No authentication on the dashboard. Risk is reduced because it listens on 127.0.0.1 (this computer only) by default, and the README states this limitation.

`mini-siem/src/mini_siem/cli.py:175: s.add_argument("--host", default="127.0.0.1")`

Recommendation: Add a login (and MFA when exposed beyond one machine) before the dashboard is used by several analysts or on a network. Until then, keep it bound to 127.0.0.1.

NIS2 Art. 21(2)(i), Art. 21(2)(j) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(d) **ISO/IEC 27001:2022** A.8.5, A.5.15, A.8.3 **GDPR** Art. 32

WEB-04 HTTP security headers are set — FAIL

No Content-Security-Policy, X-Frame-Options or X-Content-Type-Options header is set.

Recommendation: Set Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options and Referrer-Policy in an @app.after_request hook, or use Flask-Talisman.

Cyber Resilience Act Annex I, Part I(2)(b), Annex I, Part I(2)(j) **ISO/IEC 27001:2022** A.8.26, A.8.9

WEB-05 Debug mode is off — PASS

Debug mode is never enabled.

Cyber Resilience Act Annex I, Part I(2)(b) **ISO/IEC 27001:2022** A.8.9, A.8.31

Logging & monitoring

LOG-01 Security-relevant actions are logged — WARN

The tools don't use a logging framework and keep no audit trail of who changed what. Alerts only store a last-modified time.

`mini-siem/src/mini_siem/store.py:46: only a last-modified timestamp is kept`

Recommendation: Log security events with Python's logging module, and keep an audit trail of analyst actions (who changed which alert, when, from which status to which).

NIS2 Art. 21(2)(b) **DORA** Art. 10, Art. 12 **Cyber Resilience Act** Annex I, Part I(2)(l) **ISO/IEC 27001:2022** A.8.15, A.8.16 **GDPR** Art. 32

Personal data (GDPR)

PRIV-01 Personal data processing is documented — FAIL

1 project(s) process personal data; 1 don't document it: mini-siem.

`mini-siem reads: client, client_ip, email, hostname, recipient, sender, src_ip, user`

Recommendation: Add a 'Privacy & personal data' section to each such README: which personal data the tool processes (usernames, email addresses, IPs, hostnames), why, where it is stored, for how long, and which third parties receive any of it. A SOC using it typically relies on legitimate interest (GDPR Art. 6(1)(f), Recital 49: network and information security).

GDPR Art. 5(1)(a), Art. 13, Art. 30 **Cyber Resilience Act** Annex II **ISO/IEC 27001:2022** A.5.34 **NIS2** Art. 21(2)(a)

PRIV-02 Internal data is filtered before third-party lookups PASS

Private and internal IP addresses are filtered out before any external lookup, and the tests verify that none is ever sent.

```
mini-siem: mini-siem/src/mini_siem/engine.py:11
mini-siem: mini-siem/src/mini_siem/engine.py:147
mini-siem: mini-siem/src/mini_siem/parsers.py:66
mini-siem: mini-siem/src/mini_siem/parsers.py:68
```

GDPR Art. 5(1)(c), Art. 25, Art. 44 **Cyber Resilience Act** Annex I, Part I(2)(g) **ISO/IEC 27001:2022** A.5.14, A.8.12 **NIS2** Art. 21(2)(d)

PRIV-03 Stored personal data has a retention limit FAIL

Personal data is kept indefinitely in: mini-siem.

```
mini-siem: data can only be deleted all at once (mini-siem/src/mini_siem/store.py:77)
```

Recommendation: Add a retention setting and a purge command (e.g. `mini-siem purge --older-than 90d`) that deletes old events, alerts and IOC results, and document the default retention period.

GDPR Art. 5(1)(e), Art. 17 **Cyber Resilience Act** Annex I, Part I(2)(m) **ISO/IEC 27001:2022** A.8.10 **NIS2** Art. 21(2)(a)

PRIV-04 Test and demo data contain no real personal data PASS

Test and demo data use reserved domains only and are marked as fictional.

```
5 data files, 8 distinct email addresses, all on reserved domains
marked as fictional: ioc-enricher/examples/threat_report.txt
marked as fictional: ioc-enricher/tests/data/paper_lantern_dataset.json
marked as fictional: ioc-enricher/tests/data/paper_lantern_report.txt
marked as fictional: mini-siem/data/paper_lantern_logs.json
```

GDPR Art. 5(1)(c), Art. 25 **ISO/IEC 27001:2022** A.8.33, A.8.11

PRIV-05 Stored personal data is encrypted at rest WARN

mini-siem store(s) events with usernames, email addresses and IPs in a plain SQLite file. Acceptable on an encrypted laptop disk, but not documented.

Recommendation: Store the database on an encrypted disk (BitLocker / FileVault / LUKS) and document it, or use SQLCipher for application-level encryption.

GDPR Art. 32 **NIS2** Art. 21(2)(h) **DORA** Art. 9 **Cyber Resilience Act** Annex I, Part I(2)(e) **ISO/IEC 27001:2022** A.8.24, A.5.33

PRIV-06 Third-party data recipients are disclosed WARN

The README names every external service and warns against submitting sensitive data, but doesn't say what each receives, where it is based, or how long it keeps it.

```
ioc-enricher: README names VirusTotal, AbuseIPDB, URLhaus, RDAP; warns against sending sensitive data
```

Recommendation: List each external service (VirusTotal, AbuseIPDB, URLhaus, RDAP), what is sent to it, where it is based, and that VirusTotal shares submissions with its users. Organisations need a legal basis and, for transfers outside the EU, a transfer mechanism (GDPR Chapter V).

GDPR Art. 13(1)(e), Art. 28, Art. 44 **NIS2** Art. 21(2)(d) **DORA** Art. 28 **ISO/IEC 27001:2022** A.5.19, A.5.14

Resilience

RES-01 Stored data can be backed up and restored WARN

mini-siem keep(s) alerts and analyst notes in one SQLite file with no backup or export command. The logs can be re-ingested, but triage work would be lost.

Recommendation: Add an export/backup command (SQLite's online backup API) and document how to restore it.

NIS2 Art. 21(2)(c) **DORA** Art. 11, Art. 12 **Cyber Resilience Act** Annex I, Part I(2)(h) **ISO/IEC 27001:2022** A.8.13 **GDPR** Art. 32

Documentation

DOC-01 Each project has user documentation PASS

All 3 projects document installation, usage and limitations.

```
compliance-check/README.md: install yes, usage yes, limitations yes
ioc-enricher/README.md: install yes, usage yes, limitations yes
mini-siem/README.md: install yes, usage yes, limitations yes
```

Cyber Resilience Act Annex II **ISO/IEC 27001:2022** A.5.37 **NIS2** Art. 21(2)(g)

DOC-05 Licensing is clear PASS

All 3 projects have a LICENSE file; dependency licenses are listed in the SBOM appendix.

ISO/IEC 27001:2022 A.5.32 **Cyber Resilience Act** Annex I, Part II(1)

Vulnerability handling

DOC-02 A vulnerability disclosure policy exists FAIL

No SECURITY.md: someone who finds a vulnerability has no private way to report it.

Recommendation: Add a SECURITY.md: how to report a vulnerability privately (email or GitHub private vulnerability reporting), what reporters can expect and when, and which versions get fixes.

Cyber Resilience Act Annex I, Part II(5), Annex I, Part II(6), Art. 13(17) **NIS2** Art. 21(2)(e), Art. 12 **ISO/IEC 27001:2022** A.8.8, A.5.24 **DORA** Art. 10

DOC-03 The security support period is stated FAIL

No document says how long the software receives security updates.

Recommendation: State which versions receive security fixes and until when (e.g. 'the latest release; this is a learning project with best-effort support'), in SECURITY.md or the README.

Cyber Resilience Act Art. 13(8), Annex II **ISO/IEC 27001:2022** A.8.8

DOC-04 Releases are versioned with a change log WARN

Versions are declared (compliance-check: 1.0.0, ioc-enricher: 1.0.0, mini-siem: 1.0.0) but there is no change log and no release tags, so users can't see which version fixes what.

```
compliance-check: 1.0.0
ioc-enricher: 1.0.0
mini-siem: 1.0.0
```

Recommendation: Keep a CHANGELOG.md per project (Keep a Changelog format) that flags security fixes, and tag releases.

Cyber Resilience Act Annex I, Part II(4), Annex II **ISO/IEC 27001:2022** A.8.32 **DORA** Art. 9

Risk management

RISK-01 A documented risk assessment or threat model exists FAIL

No threat model or risk assessment is documented. CRA Art. 13(2) requires one for products in scope, and ISO 27001/27005 build everything on it.

Recommendation: Write a THREAT_MODEL.md per project: assets, threats (e.g. STRIDE), likelihood and impact, chosen treatment, and the risk owner. The risk register in this report is a starting point.

ISO/IEC 27005:2022 6, 7.2, 7.3, 7.4, 8 **ISO/IEC 27001:2022** 6.1.2, 6.1.3, 8.2 **NIS2** Art. 21(1), Art. 21(2)(a) **DORA** Art. 6, Art. 8 **Cyber Resilience Act** Art. 13(2), Annex VII

Incident handling

INC-01 An incident and vulnerability response procedure is documented

FAIL

No documented procedure for responding to an exploited vulnerability or a data breach.

Recommendation: Document who does what when a vulnerability in the tools is exploited or a breach happens, including the legal clocks: CRA 24 h early warning to ENISA/CSIRT, NIS2 24 h / 72 h / 1 month, GDPR 72 h to the data protection authority.

NIS2 Art. 21(2)(b), Art. 23 **DORA** Art. 17, Art. 19 **Cyber Resilience Act** Art. 14 **ISO/IEC 27001:2022** A.5.24, A.5.26 **GDPR** Art. 33, Art. 34

AI Act

AI-01 Use of AI systems (AI Act scope)

N/A

No AI system: none of 20 common ML/LLM libraries is imported or declared, and no model files are present. Verdicts come from fixed, human-written rules and thresholds, which the AI Act's definition (Art. 3(1)) excludes.

```
52 Python files and 3 pyproject.toml files inspected
```

AI Act Art. 3(1), Art. 4, Art. 5, Art. 6, Art. 50

5. Risk register (ISO/IEC 27005:2022)

Each missing or partial control is treated as a vulnerability (clause 7.2) and analysed on a 3 x 3 qualitative scale (clause 7.3): **likelihood** that the gap is exploited or causes harm, times **impact** if it does. Scores of 6-9 are high, 3-4 medium, 1-2 low (clause 7.4). A partly implemented control lowers the likelihood by one step. Ratings are defaults set per check: review them with the risk owner before accepting or treating a risk (clause 8).

Likelihood \ Impact	Low	Medium	High
Likely	1	5	
Possible	1	3	
Unlikely	2	7	2

ID	Risk and finding	L	I	Level	Treatment and action
R-01 SC-04	**Dependency updates are automated** No Dependabot or Renovate configuration: outdated or vulnerable dependencies are only found if someone looks.	3	2	High	**Modify (reduce).** Add .github/dependabot.yml (ecosystems: pip for each project folder, and github-actions) so vulnerable dependencies get update pull requests automatically. Owner: Project maintainer
R-02 PRIV-01	**Personal data processing is documented** 1 project(s) process personal data; 1 don't document it: mini-siem.	3	2	High	**Modify (reduce).** Add a 'Privacy & personal data' section to each such README: which personal data the tool processes (usernames, email addresses, IPs, hostnames), why, where it is stored, for how long, and which third parties receive any of it. A SOC using it typically relies on legitimate interest (GDPR Art. 6(1)(f), Recital 49: network and information security). Owner: Project maintainer
R-03 PRIV-03	**Stored personal data has a retention limit** Personal data is kept indefinitely in: mini-siem.	3	2	High	**Modify (reduce).** Add a retention setting and a purge command (e.g. `mini-siem purge --older-than 90d`) that deletes old events, alerts and IOC results, and document the default retention period. Owner: Project maintainer
R-04 DOC-02	**A vulnerability disclosure policy exists** No SECURITY.md: someone who finds a vulnerability has no private way to report it.	3	2	High	**Modify (reduce).** Add a SECURITY.md: how to report a vulnerability privately (email or GitHub private vulnerability reporting), what reporters can expect and when, and which versions get fixes. Owner: Project maintainer
R-05 RISK-01	**A documented risk assessment or threat model exists** No threat model or risk assessment is documented. CRA Art. 13(2) requires one for products in scope, and ISO 27001/27005 build everything on it.	3	2	High	**Modify (reduce).** Write a THREAT_MODEL.md per project: assets, threats (e.g. STRIDE), likelihood and impact, chosen treatment, and the risk owner. The risk register in this report is a starting point. Owner: Project maintainer
R-06 DEV-03	**Security-focused code scanning is enabled** No security scanner (ruff S rules, bandit, semgrep, CodeQL) is configured.	2	2	Medium	**Modify (reduce).** Enable ruff's security rules (add "S" to `select` in each pyproject.toml), or run bandit or GitHub CodeQL in CI. Owner: Project maintainer
R-07 WEB-02	**Forms are protected against cross-site request forgery** 1 POST form(s) without CSRF tokens.	2	2	Medium	**Modify (reduce).** Add CSRF tokens to every POST form (e.g. Flask-WTF's CSRFProtect). Without them, any website the analyst visits can send a hidden request to the dashboard on 127.0.0.1 and close alerts. Owner: Project maintainer

ID	Risk and finding	L	I	Level	Treatment and action
R-08 INC-01	**An incident and vulnerability response procedure is documented** No documented procedure for responding to an exploited vulnerability or a data breach.	2	2	Medium	**Modify (reduce).** Document who does what when a vulnerability in the tools is exploited or a breach happens, including the legal clocks: CRA 24 h early warning to ENISA/CSIRT, NIS2 24 h / 72 h / 1 month, GDPR 72 h to the data protection authority. Owner: Project maintainer
R-09 WEB-03	**The web interface requires authentication** No authentication on the dashboard. Risk is reduced because it listens on 127.0.0.1 (this computer only) by default, and the README states this limitation.	1	3	Medium	**Modify (reduce).** Add a login (and MFA when exposed beyond one machine) before the dashboard is used by several analysts or on a network. Until then, keep it bound to 127.0.0.1. Owner: Project maintainer
R-10 DEV-05	**Database queries are parameterised** No SQL injection found: 7 queries build their structure dynamically, but every value is passed as a parameter or checked against a fixed allow-list. A manual review of these lines is still advisable.	1	3	Medium	**Modify (reduce).** Review each query built with an f-string: values must go through ? placeholders, and any interpolated column or clause must come from a fixed allow-list, never from user input. Owner: Project maintainer
R-11 DOC-03	**The security support period is stated** No document says how long the software receives security updates.	3	1	Medium	**Modify (reduce).** State which versions receive security fixes and until when (e.g. 'the latest release; this is a learning project with best-effort support'), in SECURITY.md or the README. Owner: Project maintainer
R-12 SC-01	**Third-party dependencies are declared with versions** 3 project(s) declare all dependencies with minimum versions, but there is no lock file pinning exact versions.	1	2	Low	**Modify or retain (accept).** Declare every dependency in pyproject.toml with a minimum version, and use a lock file (e.g. pip-tools or uv) for reproducible builds. Owner: Project maintainer
R-13 SC-02	**A software bill of materials (SBOM) is available** No SBOM is published. This report lists the 8 declared component(s) in the appendix, and `--sbom` writes a CycloneDX file.	1	2	Low	**Modify or retain (accept).** Generate a CycloneDX or SPDX SBOM in CI for every release (this tool writes one with --sbom) and publish it with the release. Owner: Project maintainer
R-14 LOG-01	**Security-relevant actions are logged** The tools don't use a logging framework and keep no audit trail of who changed what. Alerts only store a last-modified time.	1	2	Low	**Modify or retain (accept).** Log security events with Python's logging module, and keep an audit trail of analyst actions (who changed which alert, when, from which status to which). Owner: Project maintainer
R-15 PRIV-06	**Third-party data recipients are disclosed** The README names every external service and warns against submitting sensitive data, but doesn't say what each receives, where it is based, or how long it keeps it.	1	2	Low	**Modify or retain (accept).** List each external service (VirusTotal, AbuseIPDB, URLhaus, RDAP), what is sent to it, where it is based, and that VirusTotal shares submissions with its users. Organisations need a legal basis and, for transfers outside the EU, a transfer mechanism (GDPR Chapter V). Owner: Project maintainer
R-16 SC-05	**CI uses third-party actions pinned to a commit** 7 action reference(s) use a movable tag instead of a commit SHA.	1	2	Low	**Modify or retain (accept).** Pin each `uses:` to a full commit SHA (with the version in a comment), and let Dependabot update them. A moved tag would otherwise run new code in CI without review. Owner: Project maintainer
R-17 SC-06	**CI jobs run with least-privilege tokens** 2 of 3 workflow(s) don't restrict the CI token.	1	2	Low	**Modify or retain (accept).** Add `permissions: contents: read` at the top of each workflow, and grant more only to the jobs that need it. Owner: Project maintainer

ID	Risk and finding	L	I	Level	Treatment and action
R-18 WEB-04	**HTTP security headers are set** No Content-Security-Policy, X-Frame-Options or X-Content-Type-Options header is set.	2	1	Low	**Modify or retain (accept).** Set Content-Security-Policy, X-Frame-Options (or frame-ancestors), X-Content-Type-Options and Referrer-Policy in an @app.after_request hook, or use Flask-Talisman. Owner: Project maintainer
R-19 PRIV-05	**Stored personal data is encrypted at rest** mini-siem store(s) events with usernames, email addresses and IPs in a plain SQLite file. Acceptable on an encrypted laptop disk, but not documented.	1	2	Low	**Modify or retain (accept).** Store the database on an encrypted disk (BitLocker / FileVault / LUKS) and document it, or use SQLCipher for application-level encryption. Owner: Project maintainer
R-20 RES-01	**Stored data can be backed up and restored** mini-siem keep(s) alerts and analyst notes in one SQLite file with no backup or export command. The logs can be re-ingested, but triage work would be lost.	1	1	Low	**Modify or retain (accept).** Add an export/backup command (SQLite's online backup API) and document how to restore it. Owner: Project maintainer
R-21 DOC-04	**Releases are versioned with a change log** Versions are declared (compliance-check: 1.0.0, ioc-enricher: 1.0.0, mini-siem: 1.0.0) but there is no change log and no release tags, so users can't see which version fixes what.	1	1	Low	**Modify or retain (accept).** Keep a CHANGELOG.md per project (Keep a Changelog format) that flags security fixes, and tag releases. Owner: Project maintainer

L = likelihood (1 unlikely, 2 possible, 3 likely). I = impact (1 low, 2 medium, 3 high). Score = L x I.

6. Organisational requirements to check by hand

These requirements depend on the organisation that builds or uses the tools, not on the code, so no scan can verify them. Tick them off with evidence (policy, record, contract, training log).

	Framework	Reference	Requirement
[ ]	**NIS2**	Art. 20	Management bodies approve the cybersecurity measures, oversee them and follow training.
[ ]	**NIS2**	Art. 23	A process exists to report significant incidents to the CSIRT (CCB in Belgium): 24 h, 72 h, 1 month.
[ ]	**NIS2**	Art. 21(2)(g)	Staff receive regular cyber hygiene and security awareness training.
[ ]	**DORA**	Art. 5-6	An ICT risk management framework is approved by the management body and reviewed yearly.
[ ]	**DORA**	Art. 28(3)	A register of information lists all contracts with ICT third-party providers (incl. the threat-intel APIs).
[ ]	**DORA**	Art. 24-27	A digital operational resilience testing programme exists (TLPT every 3 years for significant entities).
[ ]	**Cyber Resilience Act**	Art. 14	If in scope: a process to notify ENISA's single reporting platform within 24 h of an actively exploited vulnerability.
[ ]	**Cyber Resilience Act**	Art. 28, 32	If in scope: conformity assessment, EU declaration of conformity and CE marking before Dec 2027.
[ ]	**ISO/IEC 27001:2022**	Clauses 4-10	ISMS scope, information security policy, Statement of Applicability, internal audit and management review.
[ ]	**ISO/IEC 27001:2022**	A.6.3	Information security awareness, education and training for staff using the tools.
[ ]	**ISO/IEC 27005:2022**	6, 8	Risk criteria and acceptance criteria are defined; risk owners formally accept residual risks.
[ ]	**AI Act**	Art. 4	Only if AI is added later: support AI literacy of staff who use or operate it.
[ ]	**GDPR**	Art. 6	A lawful basis is identified for processing logs (usually legitimate interest, with a balancing test).
[ ]	**GDPR**	Art. 30	The SIEM and enrichment processing appear in the record of processing activities.
[ ]	**GDPR**	Art. 35	A data protection impact assessment is done if monitoring is systematic and large-scale.
[ ]	**GDPR**	Art. 28, 44-46	Agreements and transfer mechanisms exist with VirusTotal, AbuseIPDB and other external services.

Appendix A. Software bill of materials

Runtime dependencies declared in each pyproject.toml, with the version installed where the scan ran. Run with `--sbom FILE` to export this as CycloneDX 1.5 JSON.

Project	Component	Requirement	Installed	License
compliance-check	reportlab	`reportlab>=4.0`	5.0.1	BSD License
	pyyaml	`pyyaml>=6.0`	6.0.3	MIT
	requests	`requests>=2.31`	2.34.2	Apache-2.0
ioc-enricher	requests	`requests>=2.31`	2.34.2	Apache-2.0
	python-dotenv	`python-dotenv>=1.0`	1.2.3	BSD-3-Clause
mini-siem	flask	`flask>=3.0`	3.1.3	BSD-3-Clause
	pyyaml	`pyyaml>=6.0`	6.0.3	MIT
	python-dotenv	`python-dotenv>=1.0`	1.2.3	BSD-3-Clause

Appendix B. Method and limitations

The scanner reads the files git would publish (tracked, plus untracked files not ignored by .gitignore), parses every Python file into a syntax tree, and inspects CI workflows, pyproject.toml files, templates, documentation and test data. Checks look for concrete evidence and report file and line. The scan ran offline, so known vulnerabilities were not looked up (SC-03).

Limits: heuristics can miss problems or flag safe code (each FAIL and WARN should be confirmed by reading the evidence); GitHub settings such as branch protection, secret scanning and private vulnerability reporting are not visible from a clone; and legal applicability depends on facts outside the repository (commercial activity, sector, size, real data processed). This report is not legal advice, a certification audit, or a conformity assessment.

Appendix C. Sources

NIS2 Directive (EU) 2022/2555
https://eur-lex.europa.eu/eli/dir/2022/2555/oj
DORA Regulation (EU) 2022/2554
https://eur-lex.europa.eu/eli/reg/2022/2554/oj
Cyber Resilience Act, Regulation (EU) 2024/2847
https://eur-lex.europa.eu/eli/reg/2024/2847/oj
AI Act, Regulation (EU) 2024/1689
https://eur-lex.europa.eu/eli/reg/2024/1689/oj
GDPR, Regulation (EU) 2016/679
https://eur-lex.europa.eu/eli/reg/2016/679/oj
CCB: NIS2 18 April 2026 deadline for essential entities
https://ccb.belgium.be/news/nis2-18-april-2026-deadline-what-essential-entities-must-have-place
Gibson Dunn: EU AI Act Omnibus agreement, postponed high-risk deadlines
https://www.gibsondunn.com/eu-ai-act-omnibus-agreement-postponed-high-risk-deadlines-and-other-key-changes/
Browne Jacobson: CRA reporting obligations in force
https://www.brownejacobson.com/insights/cyber-resilience-act-reporting-obligations-in-force
ISO/IEC 27001:2022
https://www.iso.org/standard/27001
ISO/IEC 27005:2022
https://www.iso.org/standard/80585.html